

> Free Software Isn't Gratis

Why companies should treat Open Source as part of their infrastructure

Christopher Tineo

Senior DevOps Engineer @ Game Plan Tech

SRE DAY NYC 2026 Q2

› whoami

Christopher Tineo

Senior DevOps Engineer · Game Plan Tech



GCP Pro Cloud
Architect



CNCF
Kubestronaut



CKA



CKS

COMMUNITY

Cloud Native SDQ · KCD New York · Cloud Native NYC

UPSTREAM

Kubernetes SIG Contributor Experience · **Member**

SUB-PROJECT

Comms · **Tech Lead**

RELEASE

Kubernetes 1.37 · **Release Comms Shadow**

 [linkedin.com/in/christopher-tineo](https://www.linkedin.com/in/christopher-tineo) ·  credly.com/users/christopher-tineo

The five acts

01

Problem

The "free" in free software has a price someone pays.

02

Examples

What it looks like when the bill comes due.

03

Cost

To companies, to maintainers, to the ecosystem.

04

Solution

Treat open source like the infrastructure it is.

05

Action

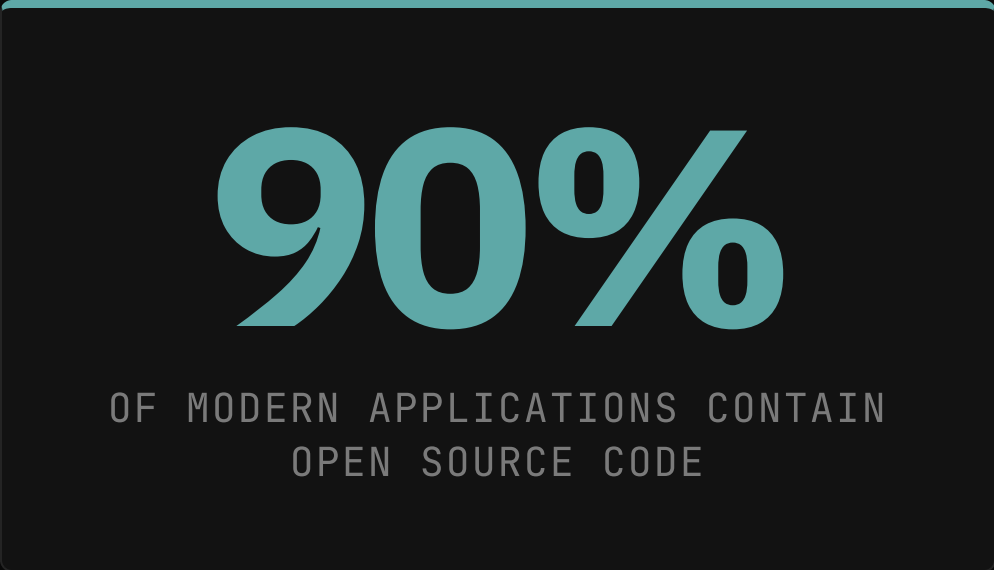
What you do on Monday morning.

ACT 01

The Problem

"Free" has a price. Someone always pays it.

Open source is everywhere



90%

OF MODERN APPLICATIONS CONTAIN
OPEN SOURCE CODE

In a typical enterprise codebase, somewhere between **70% and 90% of the lines of code** come from public open source packages — not from the engineers who shipped the product.

Source: Synopsys Open Source Security and Risk Analysis (OSSRA) report, recent editions. The number moves around year to year, but the order of magnitude does not.

› clarificatio

Free software **≠** Open source

Two overlapping but distinct philosophies. Same code, different why.

FREE SOFTWARE

A movement

- › User freedom as the goal
- › **FSF** · 1985 · Richard Stallman
- › Four freedoms (run, study, modify, share)
- › License ethos: **copyleft**

≠

OPEN SOURCE

A methodology

- › Practical benefits as the goal
- › **OSI** · 1998 · Raymond & Perens
- › 10 Open Source Definition criteria
- › License ethos: **permissive**

*Most projects are **both**. The difference is the why, not the what.*

"Free" as in beer vs "free" as in speech



Richard Stallman, founder of the GNU Project and the Free Software Foundation. His framing of "free software" — meaning freedom, not price — gave us this wordplay.

Stallman chose "free" to mean freedom (speech), not price (beer).

The English language has only one word for both, causing 40 years of etymological confusion.

This talk is about the gap between them — and who pays for it.

ACT 02

The Examples

What it looks like when the bill comes due.

What is ingress-nginx?



The front door to your Kubernetes cluster.

Routes external traffic into your services.

Maintained by a handful of unpaid SIG Network volunteers.

~60%

SCOPE AT END OF 2025

of deployments relied on ingress-nginx as an ingress controller.

Source: [CNCF End User TAB](#) · Apr 2026



Scan to
read CNCF
report

"In 9 years, ingress-nginx had exactly one 'call for maintainers' issue."

It got 10 thank-you comments and 0 volunteers.



↳ [@aledbf stepping down · kubernetes/ingress-nginx#4404](https://github.com/kubernetes/ingress-nginx/issues/4404)

The announcement → EOL

Mar 2025

Maintenance Mode: Entering security-only maintenance. No new features.

Mid 2025

Migration Scramble: Downstream projects begin coordinating emergency migrations.

Mar 2026

End of Life: Security updates stop. Production workloads are on borrowed time.

Now

The Legacy Gap: Thousands of organizations are still running unsupported ingress controllers.

Source: [Kubernetes project — Ingress NGINX retirement statement](#)



Scan to read statement

The humans behind the controller

14.7k

total issues over 9 years

8

critical CVEs in 2 years

50+

issues permanently frozen

\$0

compensation for maintenance

› what they actually do (\$0 budget · after hours · on weekends)

Triage & Review · CVE Patching · Release Management · End-User Support

@RIKATZ · DEC 15, 2024 · KUBERNETES/ORG#5305

"I need some time for myself, and I am not really being able to take care of the project and my personal life together :)"

Why it collapsed

THE CVE MANIA

Eight significant CVEs and RCEs in two years — and the maintainers who had to fix them were not being paid to do it.

› 2022 · June

"we're drowning" mailing list
call

› 2024 · May

CVE cascade forces emergency
patches

› 2025 · March

CVE-2025-1974 RCE forces final
EOL

CVE Overload: 2 maintainers fixing 8 CVEs without compensation.
Unpaid labor scaled with security debt.

Replacement Abandoned: InGate shipped and retired
simultaneously. No volunteers for free work.

Triage Frozen: 50+ issues frozen because the queue became
impossible to review.

Corporate Rescue Declined: Steering declined last-minute takeover
citing security trust risks.

"This is fine." 

ACT 03

The Cost

To companies. To maintainers. The AI threat.

Cost to companies

50%

of cloud-native environments are affected, relying on `ingress-nginx` as critical infrastructure.

Zero

direct 1-1 drop-in replacements exist. Every migration requires manual annotation translation.

OFFICIAL STEERING COMMITTEE STATEMENT

"None of the available alternatives are direct drop-in replacements. This will require planning and engineering time."

Translate hundreds of custom Nginx annotations. Unplanned migrations are measured in **engineer-months** of lost roadmap velocity.

Source: Kubernetes Blog (Jan 2026)

[Read statement](#) 



Scan to
read
statement

Cost to maintainers

60%

of open source maintainers are unpaid
for their work

SOURCE: BYTEIOTA / IT'S FOSS

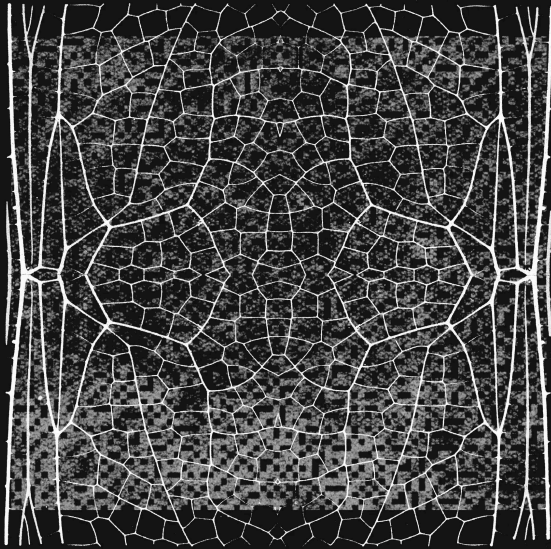
@BENTHEELDER · STEERING COMMITTEE · JAN 21, 2026

"Nobody has been paying anyone to work on this software for some time, it has been entirely volunteer driven and they've been overwhelmed."

The cost is the most expensive line item in this talk: time, health, and career impact. A salary or protected time would have changed the math.

The CVE cascade turned volunteer contributions into an unpaid second job with constant security liability.

Vulnerabilities are becoming significantly more frequent and severe due to AI



Project Glasswing · Anthropic Mythos Preview

BLACK DUCK 2026 OSSRA

Open source vulnerabilities **doubled** to 581 per codebase. 87% of codebases are at risk.

ANTHROPIC GLASSWING

Mythos Preview found **10k+** high/critical bugs. Open-source scan: **90.6%** true positive rate (on track for **3,900** validated).

THREAT ACCELERATION

Bad actors also have these AI models, accelerating zero-day discovery and exploitation.

ACT 04

The Solution

Stop calling it free. Start treating it like infrastructure.

Open source is critical infrastructure

If 70–90% of your code is open source, dependencies are your infrastructure.

And we already know how to treat critical infrastructure:

MONITOR

Watch for advisories, EOL announcements, maintainer health signals.

SET SLOS

Define what "healthy" means for each critical dependency.

STAFF IT

Assign owners. Budget time. Treat maintainer relationships as a critical asset.

What could I do?

01 · DISCOVER

Discover

What are you actually depending on?
Generate a complete SBOM. Know your transitive graph.

02 · ASSESS

Assess

For each critical dependency: how many maintainers?
Who funds it? Is there a **lottery factor** of one?

03 · FUND

Fund

Direct sponsorship, GitHub Sponsors, Open Collective, foundation dues, LF Foundations, Whatever works.

04 · CONTRIBUTE

Contribute

Time, code, reviews, documentation, security disclosures.
The most valuable currency isn't money; it's attention.

› the new reali

The build-vs-buy equation has flipped

AI is driving down development costs,
flipping the build-vs-buy equation.
Traditional SaaS margins are eroding.

\$1T+

SaaS market cap lost in a single
month

+15%

US engineering job growth (BLS
2034)

SCAN TO WATCH TALK

Source: ["Build vs. Buy Is Dead" \(YouTube\)](#)



OSS IS THE ENGINE

We build on open source—and pay our share
by contributing fixes upstream.

GAME PLAN TECH • CASE STUDY

Added GCS Workload Identity support to Percona
MongoDB Operator for a federal compliance workload.

Rather than maintaining a private fork, contributing upstream
solved it for us and the community.

UPSTREAM PULL REQUEST

[percona-operator#2315](#)



Scan to
view PR

ACT 05

The Action

What you do on Monday morning.

What you do on Monday

LEADERS & SRE TEAMS

Before adding a new dependency to your tech stack:

"If the core maintainer for this project won the lottery, what's the worst thing that could happen to your project?"

INDIVIDUAL CONTRIBUTORS

Have you ever thought, "Ugh, this project is great but if it had this X feature it would fit my needs perfectly"?

Open a Github Issue and contribute back!

› terminal

Tagging & tracking with gh / glab

GITHUB CLI (GH)

```
# Loop all repos & fetch transitives (Free)
$ for repo in $(gh repo list --limit 100 \
  --json nameWithOwner -q '.[].nameWithOwner'); do
  gh api repos/$repo/contents/package-lock.json \
    -H "Accept: application/vnd.github.raw" | \
    jq -r '.packages | keys[] | select(. ≠ "")'
done

# Bulk check Lottery Factor (>10 contributors)
$ for repo in $(gh repo list --limit 100 \
  --json nameWithOwner -q '.[].nameWithOwner'); do
  gh api repos/$repo/contributors \
    --jq '.[[] | select(.contributions > 10)] | length'
done

# Bulk Tag / Star dependency repos
$ for repo in $deps; do
  gh repo edit $repo --add-topic "critical-dep"
  gh api -X PUT user/starred/$repo
done
```

GITLAB CLI (GLAB)

```
# Loop all projects & fetch transitives (Free)
$ for repo in $(glab repo list -F json | \
  jq -r '.[].path_with_namespace'); do
  enc="${repo//\///%2F}"
  glab api projects/$enc/repository/files/package-lock.json/raw | \
    jq -r '.packages | keys[] | select(. ≠ "")'
done

# Bulk check Lottery Factor (>10 commits)
$ for repo in $(glab repo list -F json | \
  jq -r '.[].path_with_namespace'); do
  enc="${repo//\///%2F}"
  glab api projects/$enc/repository/contributors | \
    jq 'map(select(.commits > 10)) | length'
done

# Bulk Tag / Star GitLab projects
$ for repo in $deps; do
  enc="${repo//\///%2F}"
  glab api -X PUT projects/$enc -F "topics=critical-dep"
  glab api -X POST projects/$enc/star
done
```

> enterprise-t

Automating with OSS Review Toolkit (ORT)

GITHUB ACTION

```
- name: Run ORT Analyzer
  uses: oss-review-toolkit/ort-ci-github-action@v1
  with:
    vcs-url: "https://github.com/TineoC/contributor-site"
    output-dir: "ort-output"
```

GITLAB CI/CD

```
ort_analyzer:
  image: ghcr.io/oss-review-toolkit/ort:latest
  script:
    - ort analyze -i . -o ort-output
```

Explore compliance tools: [ORT](#) · [Snyk](#) · [GitHub Dependency Graph](#)



REPORT: GITHUB.COM/TINEOC

This is fine.

It's only fine if we pay for it.

🤝 Thank you · Christopher Tineo · Game Plan Tech

kubernetes.io/blog/2026/01/29/ingress-nginx-statement · gnu.org/philosophy/free-sw

Happy 12th Anniversary, Kubernetes!



12 YEARS OF CLOUD-NATIVE INNOVATION (2014 - 2026)



ONE MORE THING

Celebrating 12 years of Kubernetes: Your free ticket to KCD New York 2026



tickets.kcdnewyork.com/redeem



 June 10, 2026

Voucher: **KCDNY26-CHRIS-ORGANIZER-FREE**

 Scan the QR code or enter the voucher at checkout. One ticket per attendee.

FIND ME • TAKE THE SLIDES

Let's keep in touch



 *LinkedIn*

linkedin.com/in/christopher-tineo



 *Slides*

github.com/TineoC/talks